JOHN MERVIN I. AGNO
BSIT-4201

Why IT Auditing Matters in a Technology-Dependent Organization

A Case Study of Riverside General Hospital

Riverside General Hospital is a mid-sized, 300-bed hospital that serves a metropolitan community with emergency, surgical, and outpatient care. Like most modern hospitals, Riverside runs almost entirely on interconnected information systems. Its electronic health record (EHR) platform stores patient histories, lab results, and medication orders; networked medical devices such as infusion pumps and monitors transmit data in real time; and billing, scheduling, and telehealth systems all depend on continuous network access. If any of these systems fail or are compromised, clinicians lose access to the information they need to treat patients safely, and the hospital risks financial, legal, and reputational damage. Because patient safety and privacy are directly tied to system reliability and data protection, Riverside cannot treat IT as a background utility — it is core infrastructure that must be actively verified and controlled, which is precisely where IT auditing becomes essential.

IT auditing is the independent, systematic examination of an organization's information systems, technology infrastructure, and related controls to determine whether they are secure, reliable, properly managed, and compliant with relevant laws, regulations, and internal policies. In simple terms, it is a health check for technology: an IT auditor gathers evidence about how systems are configured and used, compares that evidence against accepted standards, and reports on whether the organization's technology can be trusted to protect data, support operations, and meet its legal obligations. At a hospital like Riverside, the IT auditor acts as an independent evaluator who works alongside — but separately from — the IT department. The auditor reviews access controls to the EHR, tests whether patient data is encrypted and backed up properly, checks

whether medical devices and software are patched against known vulnerabilities, and verifies that staff follow policies for handling protected health information (PHI). Rather than simply trusting documentation, the auditor interviews staff, reviews system logs, and tests controls directly. The end product is a report to hospital leadership and the board that identifies weaknesses, ranks their risk, and recommends corrective action, giving management the assurance needed to make informed decisions about technology investment and risk management.

Several types of IT audits are especially relevant to a hospital environment. A security audit is critical because Riverside stores highly sensitive patient data; it tests firewalls, encryption, endpoint protection, and incident-response procedures to determine how well the hospital can prevent and detect cyberattacks such as ransomware. A compliance audit is equally important, since hospitals are legally required to protect electronic PHI under HIPAA; this type of audit checks whether Riverside's policies, access controls, and audit logs actually satisfy the HIPAA Security and Privacy Rules, reducing the risk of federal penalties following an Office for Civil Rights review. An operational, or systems, audit matters because clinical staff depend on the EHR and connected devices every minute of every shift; it evaluates system uptime, change-management practices, and disaster-recovery planning to ensure continuity of patient care. Finally, an application audit focused specifically on the EHR and billing applications verifies that data entered by clinicians and coders is accurate, that automated calculations such as medication dosing alerts function correctly, and that only authorized users can modify records. Together, these audit types address the technical, regulatory, and clinical dimensions of Riverside's dependence on technology.

Regular IT auditing offers Riverside several concrete benefits. By identifying vulnerabilities before attackers do, audits reduce the risk of a costly and damaging breach of patient data.

Demonstrating compliance with HIPAA and related standards also protects the hospital from fines, corrective action plans, and reputational harm that would follow a regulatory investigation. Beyond security and compliance, auditing change-management and backup practices improves the reliability of patient care systems, helping ensure the EHR and medical devices remain available when clinicians need them most. Finally, a documented track record of independent audits builds greater trust among patients, insurers, and regulators, reassuring them that Riverside takes data protection seriously rather than treating it as an afterthought.

To be effective and credible, the IT auditor at Riverside should be guided by several core principles. Independence and objectivity come first: the auditor must be free from influence by the IT department or hospital management so that findings are unbiased and trustworthy. Confidentiality is equally important, since the auditor will encounter PHI and sensitive system details during the engagement, and that information must be protected and used only for audit purposes. Due professional care and competence require the auditor to apply appropriate skill, follow recognized standards such as ISACA's Information Technology Assurance Framework (ITAF), and gather sufficient, reliable evidence before forming conclusions. Finally, a risk-based approach ensures that, with limited time and resources, the auditor focuses first on the areas of greatest risk to patient safety and data protection, such as systems holding ePHI or supporting critical care. Together, these principles keep the audit both rigorous and genuinely useful to the organization it serves.

A realistic and pressing risk facing Riverside is a ransomware attack that encrypts EHR data and forces clinicians back to paper records, delaying diagnoses and treatment. An IT audit could help management address this risk well before it materializes by testing backup and recovery procedures, verifying that critical systems are patched and segmented from less-secure parts of the

network, and confirming that staff are trained to recognize phishing attempts, which are the most common entry point for ransomware. By surfacing these gaps in advance, IT auditing gives Riverside's leadership the information needed to strengthen defenses, protect patients, and avoid the operational chaos and financial cost of a major cyber incident.

References

1. HHS Office for Civil Rights. (2024). *OCR's HIPAA audit program*. U.S. Department of Health and Human Services. https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/audit/index.html

2. Cooke, I. (2020). *IS audit basics: The components of the IT audit report*. *ISACA Journal, 1*. ISACA. https://www.isaca.org/resources/isaca-journal/issues/2020/volume-1/is-audit-basics-the-components-of-the-it-audit-report

3. ISACA. (n.d.). *Information Technology Assurance Framework (ITAF)*. https://www.isaca.org/resources/itaf

4. Schellman & Company. (2023). *The benefits of HIPAA assessments for healthcare organizations*. https://www.schellman.com/blog/hipaa/the-benefits-of-hipaa-assessments-for-healthcare-organizations